

Ley 1581 de 2012

Protección de Datos Personales

Owl Compliance · Bogotá, Colombia

SCORE DE CUMPLIMIENTO

33%

Responsable de tratamiento: Nicolás Almeyda Orozco

NIT: [por confirmar]

Domicilio: Bogotá, Cundinamarca, Colombia

Fecha de auditoría: 22 de junio de 2026

Commit auditado: 1468c74

RNBD: No obligada (microempresa, activos $\leq$ 100.000 UVT)

Este documento es un borrador de cumplimiento fundado en la normativa colombiana.

No constituye asesoría legal.

Resumen ejecutivo

Resumen Ejecutivo de Cumplimiento — Ley 1581 de 2012

Empresa: Owl Compliance · **NIT:** [por confirmar]

Responsable: Nicolás Almeyda Orozco

Fecha: 1 de julio de 2026

Corrida anterior: 22 de junio de 2026

Puntuación global

Métrica	Corrida anterior	Esta corrida	Variación
Score	33% (commit 1468c74)	42% (commit 0bb29ef)	+9 pp
Controles evaluables	24	24	—
Pass	5	7	+2
Partial	4	6	+2
Fail	13	11	-2
Unknown	2	2	—
Scope	Solo app/	App + deploy/	ampliado

$Score = (pass + 0.5 \times partial) / evaluables = (7 + 3) / 24 = 42\%$

Avances desde la corrida anterior

Mejoras confirmadas en código (commit 82e11f9)

Control	Antes	Ahora	Cambio
sec-passwords	fail — SHA-256	pass — bcrypt costo 12, migración silenciosa al login	Implementado
sec-rest	partial — tokens en claro en BD	pass — AES-256-GCM (lib/storage-crypto.ts)	Implementado
inc-brechas	fail — sin documentación	partial — plan y registro generados (.compliance/docs/)	Documentado
data-eipd	fail	partial — EIPD generada como buena práctica	Documentado

Nuevos archivos de documentación (.compliance/)

Todos los documentos del pack ley-1581 están generados:

- Política de privacidad completa
- Aviso de privacidad (para login y formularios)
- Autorización de tratamiento (con código SQL + frontend)
- Canal de Habeas Data

- Cláusula de encargo a proveedores
- Plan de respuesta a brechas
- Registro de incidentes
- Procedimiento RNBD (no obligada)
- EIPD

Nuevos hallazgos — Deploy (web pública)

El alcance de esta corrida se amplió a `D:\0WL\deploy`. Se identificó que `autodiagnostico.html` recoge datos personales de prospectos:

Datos recopilados: empresa, representante legal, cargo, email, teléfono, RUTIC, servicios.

Encargados involucrados:

- EmailJS (USA) — notificación al equipo de ventas
- Google Sheets vía Apps Script (USA) — almacenamiento de leads

Problemas:

1. **Sin aviso de privacidad** antes del formulario (Art. 10 Ley 1581).
2. **Sin checkbox de autorización** — el envío ocurre sin consentimiento explícito (Art. 9 Ley 1581).
3. **Sin DPA con EmailJS** (Google LLC ya tiene DPA disponible).
4. **Sin plazo de retención** definido para los leads en Google Sheets.

Esto agrava los controles `data-licitud`, `data-autorizacion`, `data-encargados` y `data-info`.

Nuevo documento generado: Base de datos 6 en `docs/1581-rat.md` (leads/prospectos).

Plan de acción priorizado

Alta prioridad — Obligaciones legales directas (Arts. 9, 10 Ley 1581)

#	Tarea	Archivo guía	Responsable
1	Agregar aviso de privacidad y checkbox de autorización en <code>autodiagnostico.html</code> antes del botón Enviar	<code>docs/1581-autorizacion-tratamiento.md</code>	Dev / Nicolás
2	Agregar aviso de privacidad + enlace a política en el login de la app (<code>app/login/page.tsx</code>)	<code>docs/1581-aviso-privacidad.md</code>	Dev
3	Publicar política de privacidad en <code>/privacidad</code> de la app y enlazarla desde el footer del deploy	<code>docs/1581-politica-privacidad.md</code>	Dev
4	Crear canal de Habeas Data y publicarlo en la política + footer	<code>docs/1581-canal-habeas-data.md</code>	Nicolás

Media prioridad — Gestión de encargados

#	Tarea	Referencia
5	Aceptar Data Processing Amendment de Google (cubre Drive, Sheets y Apps Script)	google.com/about/company/user-consent-policy
6	Verificar DPA de Turso (turso.tech/legal)	<code>docs/1581-clausula-encargados.md</code>
7	Verificar DPA de Resend (resend.com/legal)	<code>docs/1581-clausula-encargados.md</code>
8	Verificar DPA de Microsoft (microsoft.com/trust-center)	<code>docs/1581-clausula-encargados.md</code>

9	Verificar si EmailJS tiene DPA o evaluar reemplazarlo con Resend para notificaciones	docs/1581-clausula-encargados.md
---	--	----------------------------------

Baja prioridad — Buenas prácticas / robustez

#	Tarea
10	Aprobar formalmente el plan de respuesta a brechas (firma del responsable) y comunicarlo al equipo
11	Implementar MFA para cuentas admin (TOTP o magic link)
12	Documentar plazo de retención de leads en Google Sheets + proceso de supresión
13	Definir plazos de conservación en el RAT (campos con [COMPLETAR])
14	Implementar alertas sobre el audit_log
15	Actualizar EIPD para incluir el flujo de leads del autodiagnóstico

Proyección de score al completar las acciones

Escenario	Score estimado
Actual (hoy)	42%
Tras acciones 1-4 (aviso + autorización + política + canal)	~58%
Tras acciones 1-9 (+ DPAs con encargados)	~67%
Tras acciones 1-15 (plan completo)	~83%

El 100% teórico requiere controles organizacionales (capacitación anual, monitoreo, backups documentados) que no son verificables por código.

Documentos generados en esta corrida

Archivo	Descripción
.compliance/state.json	Estado completo de controles
.compliance/docs/1581-rat.md	RAT con 6 bases de datos (incluye leads del autodiagnóstico)
.compliance/docs/1581-politica-privacidad.md	Política de privacidad completa
.compliance/docs/1581-aviso-privacidad.md	Aviso corto para formularios y login
.compliance/docs/1581-autorizacion-tratamiento.md	Código para capturar autorización
.compliance/docs/1581-canal-habeas-data.md	Canal y procedimiento Habeas Data
.compliance/docs/1581-clausula-encargados.md	DPA tipo + lista de encargados (incl. EmailJS, Google Sheets)
.compliance/docs/1581-plan-respuesta-brechas.md	Plan de respuesta a incidentes
.compliance/docs/1581-registro-incidentes.md	Registro de incidentes
.compliance/docs/1581-procedimiento-rnbd.md	RNBD — no obligada
.compliance/docs/1581-eipd.md	Evaluación de impacto
.compliance/INSTRUCTIVO.md	Runbooks operacionales

Registro de Actividades de Tratamiento (RAT)

Registro de Actividades de Tratamiento (RAT) — Ley 1581 de 2012

Responsable del tratamiento: Owl Compliance
NIT: [NIT por confirmar]
Domicilio: Bogotá, Cundinamarca, Colombia
Correo de contacto protección de datos: [correo por confirmar — ej. datos@owlcompliance.co]
Representante legal / Responsable designado: Nicolás Almeyda Orozco
Fecha de elaboración: 22 de junio de 2026
Versión: 1.0

Base legal: Art. 17 lit. a y b Ley 1581 de 2012; Art. 25 Decreto 1377 de 2013.

Este RAT debe revisarse anualmente o ante cambios materiales en el tratamiento.

Base de datos 1 — Usuarios de la plataforma

Campo	Detalle
Usuarios del sistema	
Nombre, correo electrónico, contraseña (hash), rol (admin/cliente), estado activo/inactivo	
Administradores de Owl Compliance; representantes de empresas clientes	
Autenticación y control de acceso a la plataforma; gestión de usuarios	
Autorización previa, expresa e informada del titular (Art. 9 Ley 1581); ejecución de relación contractual	
Durante la vigencia de la relación contractual + [COMPLETAR: ej. 5 años] para efectos legales/contables	
Turso Inc. (EE.UU.) — almacenamiento en BD libSQL	
Transmisión a Turso (EE.UU.) como encargado. EE.UU. tiene nivel adecuado reconocido por la SIC	
No	
No	
Hash de contraseña con bcrypt costo 12 (lib/password.ts), JWT para sesiones, control de acceso por rol, audit_log. Tokens OAuth cifrados con AES-256-GCM (lib/storage-crypto.ts).	

Base de datos 2 — Clientes (empresas ISP)

Campo	Detalle
	Clientes del servicio de compliance
	Razón social, NIT, nombre persona de contacto, correo electrónico, teléfono
	Personas jurídicas (datos de contacto) y personas naturales (representantes/contactos) de empresas ISP
	Prestación del servicio de gestión de cumplimiento regulatorio; comunicaciones sobre obligaciones y recordatorios
	Ejecución de contrato de servicios; autorización del titular persona natural (Art. 9 Ley 1581)
	Durante la vigencia del contrato + [COMPLETAR: ej. 5 años]
	Turso Inc. (EE.UU.) — almacenamiento; Resend (EE.UU.) — envío de correos de recordatorio
	Transmisión a Turso y Resend (EE.UU.) como encargados. EE.UU. con nivel adecuado SIC
	No
	No
	Segregación por cliente_id, control de acceso por rol, audit_log

Base de datos 3 — Mensajes y conversaciones (chat)

Campo	Detalle
	Conversaciones y mensajes
	Contenido de mensajes de texto, identificadores de usuario, timestamps
	Admins de Owl Compliance; representantes de clientes
	Comunicación y soporte entre Owl Compliance y sus clientes en la plataforma
	Ejecución del servicio contratado; autorización implícita en el uso de la plataforma
	[COMPLETAR: ej. 2 años desde cierre de la conversación]
	Turso Inc. (EE.UU.)
	No (potencialmente pueden contener datos de terceros si el cliente los comparte — recomendación: no incluir datos sensibles en el chat)

Base de datos 4 — Documentos de cumplimiento

Campo	Detalle
Documentos subidos por clientes	
Nombre de archivo, ruta de almacenamiento, metadatos (quién subió, fecha)	
Admins de Owl Compliance; representantes de clientes	
Acreditación del cumplimiento regulatorio de los clientes ISP	
[COMPLETAR: ej. durante la vigencia del contrato + 5 años]	
Turso (metadatos); Google Drive / Microsoft OneDrive/SharePoint (almacenamiento de archivos, según configuración del cliente)	
Google LLC (EE.UU.) y Microsoft Corp. (EE.UU.) — nivel adecuado SIC	
Los documentos pueden contener datos de terceros (empleados, clientes del ISP) — responsabilidad del cliente ISP como responsable	

Base de datos 5 — Bitácora de auditoría (audit_log)

Campo	Detalle
Registro de auditoría del sistema	
user_id, user_email, acción, entidad afectada, detalle (JSON), dirección IP, timestamp	
Usuarios internos (admins y representantes de clientes)	
Trazabilidad de cambios; detección de accesos no autorizados; cumplimiento de obligaciones de seguridad	
Obligación legal y legítimo interés (seguridad de la información, Art. 17 lit. i Ley 1581)	
[COMPLETAR: ej. 5 años — recomendado para efectos de inspección SIC]	
No	

Base de datos 6 — Leads y prospectos del autodiagnóstico (web pública)

Campo	Detalle
Leads del autodiagnóstico público	

Empresa, nombre del representante, cargo, correo electrónico, teléfono, RUTIC (identificador de operador), servicios seleccionados
Personas naturales (representantes y contactos de empresas ISP) que completan el autodiagnóstico en owlcompliance.co
Calificación comercial de prospectos; contacto para oferta del servicio de compliance
Autorización del titular (Art. 9 Ley 1581) —
[COMPLETAR: ej. 12 meses desde la captación, o hasta que el prospecto solicite supresión]
EmailJS (EE.UU.) — envío de notificación al equipo Owl Compliance; Google LLC (EE.UU.) — almacenamiento en Google Sheets vía Apps Script
EmailJS (EE.UU.) y Google Sheets/Apps Script (EE.UU.) — nivel adecuado SIC
No
No
HTTPS del formulario (según hosting). Sin autorización explícita ni registro de consentimiento — INCUMPLIMIENTO
1) Agregar aviso de privacidad antes del formulario. 2) Agregar checkbox de autorización. 3) Registrar timestamp y versión del aviso aceptado en la hoja de Google Sheets. 4) Documentar plazo de retención y proceso de supresión.

Proveedores / encargados del tratamiento

Proveedor	País	Datos que recibe	DPA firmado	Nivel adecuado SIC
Turso Inc.	EE.UU.	BD completa (usuarios, clientes, mensajes, documentos)	[COMPLETAR: verificar ToS de Turso]	☒ Sí
Resend	EE.UU.	email_destino, contenido del recordatorio	[COMPLETAR: verificar ToS de Resend]	☒ Sí
Google LLC	EE.UU.	Tokens OAuth, documentos en Google Drive,	[COMPLETAR: Data Processing Amendment de Google — cubre Workspace y APIs]	☒ Sí
Microsoft Corp.	EE.UU.	Tokens OAuth, documentos en OneDrive/SharePoint	[COMPLETAR: Data Processing Agreement de Microsoft]	☒ Sí
EmailJS	EE.UU.	email_destino, nombre, empresa, teléfono (notificación de lead)	[COMPLETAR: verificar ToS EmailJS o suscribir DPA]	☒ Sí

Nota: Todos los proveedores son encargados del tratamiento (procesan datos bajo instrucción de Owl Compliance). No son transferencias a responsables internacionales; son transmisiones. EE.UU. tiene nivel adecuado de protección reconocido por la SIC (Circular Única — Título V, numeral 3.2, versión 29-09-2022).

Decisiones de diseño relevantes para privacidad

- **Segregación multi-tenant:** cada cliente tiene un `cliente_id` ; todas las consultas filtran por este ID. Implementado en lib/clientes.ts y todas las API routes.
 - **Control de acceso por roles:** admin, cliente, superadmin con verificación en middleware y API routes.
 - **No se procesan datos sensibles** de los titulares personas naturales (Art. 6 Ley 1581).
 - **No hay usuarios menores de edad** en la plataforma.
-

Borrador generado con compliance-co (pack ley-1581). No constituye asesoría legal.

Política de Privacidad

Política de Tratamiento de Datos Personales

Owl Compliance — Owl Compliance

Versión: 1.0

Fecha de vigencia: [COMPLETAR: fecha de publicación]

Última actualización: 22 de junio de 2026

1. Responsable del tratamiento

Owl Compliance, con NIT [por confirmar], domiciliada en Bogotá, Cundinamarca, Colombia, correo electrónico: [COMPLETAR: ej. datos@owlcompliance.co], teléfono: [COMPLETAR].

Marca comercial: **Owl Compliance** — Centro de Cumplimiento Regulatorio para ISPs.

2. Marco legal

Esta política se rige por la **Ley 1581 de 2012** (Habeas Data comercial) y el **Decreto 1377 de 2013** (compilado en Decreto 1074 de 2015), aplicables al tratamiento de datos personales de personas naturales en Colombia. Fiscaliza: **Superintendencia de Industria y Comercio (SIC)**.

3. Ámbito de aplicación

Esta política aplica a todos los datos personales de personas naturales que Owl Compliance recopile, almacene, use o transmita en el desarrollo de su plataforma de gestión de cumplimiento regulatorio para proveedores de servicios de telecomunicaciones (ISPs).

No aplica a los datos de personas jurídicas como tales, ni a los datos de los clientes finales de los ISPs usuarios de la plataforma (cuyo tratamiento es responsabilidad de cada ISP).

4. Datos personales que tratamos

Tratamos las siguientes categorías de datos personales:

Categoría	Datos	Titulares
Identificación y contacto	Nombre, correo electrónico, teléfono	Administradores; representantes de clientes ISP
Acceso a la plataforma	Correo electrónico, contraseña (almacenada como hash), rol	Todos los usuarios registrados
Información de la empresa	Razón social, NIT, persona de contacto, correo y teléfono de la empresa	Representantes de clientes ISP
Comunicaciones	Contenido de mensajes en el chat interno de la plataforma	Usuarios de la plataforma

Auditoría y seguridad	Registro de acciones (qué usuario hizo qué acción, cuándo y desde qué IP)	Usuarios de la plataforma
-----------------------	---	---------------------------

Recordatorios	Correo electrónico de destino para notificaciones de vencimiento	Administradores y contactos de clientes
---------------	--	---

No tratamos datos sensibles (Art. 6 Ley 1581): no recopilamos datos de salud, biométricos, origen racial, opiniones políticas, convicciones religiosas ni datos procesales penales.

No atendemos usuarios menores de edad. La plataforma está dirigida exclusivamente a personas jurídicas y sus representantes legales mayores de edad.

5. Finalidades del tratamiento

Tratamos sus datos personales para:

- Autenticación y acceso:** verificar su identidad y gestionar el acceso a la plataforma.
- Prestación del servicio:** gestionar las obligaciones de cumplimiento regulatorio de su empresa ISP.
- Comunicaciones del servicio:** enviar recordatorios de vencimiento de obligaciones y notificaciones operativas.
- Soporte y atención:** gestionar sus consultas y solicitudes a través del chat y sistema de tickets.
- Seguridad y auditoría:** registrar acciones para detectar accesos no autorizados y garantizar la trazabilidad.
- Cumplimiento legal:** cumplir con obligaciones legales aplicables a Owl Compliance.

6. Base de licitud del tratamiento

El tratamiento se basa en:

- Autorización previa, expresa e informada del titular** (Art. 9 Ley 1581) — obtenida al momento del registro en la plataforma.
- Ejecución del contrato de servicios** suscrito con la empresa cliente.
- Obligación legal** para el mantenimiento de registros de auditoría y seguridad (Art. 17 lit. i Ley 1581).

7. Derechos del titular (Habeas Data)

Como titular de datos personales, usted tiene derecho a:

Derecho	Descripción	Plazo de respuesta
	Conocer qué datos tenemos sobre usted y para qué los usamos	10 días hábiles (prorrogable 5 días hábiles más, avisando antes del vencimiento)
	Corregir datos inexactos o desactualizados	15 días hábiles (prorrogable 8 días hábiles más)
	Solicitar la eliminación de sus datos cuando no haya obligación legal de conservarlos	15 días hábiles
	Retirar el consentimiento para el tratamiento	15 días hábiles

Para ejercer estos derechos, contacte: **[COMPLETAR: ej. datos@owlcompliance.co]** con el asunto "Solicitud Habeas Data".

8. Encargados del tratamiento y transmisiones internacionales

Owl Compliance trabaja con los siguientes encargados del tratamiento, a quienes transmite datos personales bajo contrato para la prestación del servicio:

Proveedor	País	Función	Nivel adecuado (SIC)
Turso Inc.	Estados Unidos	Base de datos en la nube	✓ Sí
Resend	Estados Unidos	Envío de correos de recordatorio	✓ Sí
Google LLC	Estados Unidos	Almacenamiento opcional de documentos (Google Drive)	✓ Sí
Microsoft Corporation	Estados Unidos	Almacenamiento opcional de documentos (SharePoint/OneDrive)	✓ Sí

Todos los países anteriores cuentan con nivel adecuado de protección reconocido por la SIC (Circular Única — Título V, numeral 3.2). No realizamos transferencias de datos a responsables en países sin nivel adecuado.

9. Seguridad de la información

Aplicamos medidas técnicas, administrativas y humanas proporcionales al riesgo para garantizar la confidencialidad, integridad y disponibilidad de sus datos personales, entre ellas:

- Cifrado de contraseñas mediante función de hashing segura.
- Control de acceso basado en roles (admin / cliente / superadmin).
- Registro de auditoría de todas las acciones relevantes.
- Segregación de datos por cliente (multi-tenant).
- Uso de variables de entorno para credenciales y secretos.
- Comunicaciones cifradas mediante TLS/HTTPS en producción.

En caso de un incidente de seguridad que afecte sus datos, le notificaremos dentro del plazo legal y reportaremos a la SIC según corresponda.

10. Plazos de conservación

Conservamos sus datos personales durante el tiempo necesario para cumplir las finalidades descritas y las obligaciones legales aplicables:

- **Datos de usuarios y clientes:** durante la vigencia de la relación contractual y [COMPLETAR: ej. 5 años] después de su terminación.
- **Registros de auditoría:** [COMPLETAR: ej. 5 años] desde la fecha del registro.
- **Mensajes y conversaciones:** [COMPLETAR: ej. 2 años] desde el cierre de la conversación.

11. Modificaciones a esta política

Notificaremos cambios materiales a esta política con al menos 10 días hábiles de anticipación, a través del correo electrónico registrado en la plataforma.

12. Vigencia

Esta política rige a partir del [COMPLETAR: fecha de publicación].

Owl Compliance — Owl Compliance · [COMPLETAR: ciudad], Colombia · [correo por confirmar]

Este documento es un borrador generado con compliance-co (pack ley-1581). No constituye asesoría legal.

Aviso de Privacidad

Aviso de Privacidad — Owl Compliance

Para incluir en el formulario de login / creación de usuario, visible antes de recoger datos.

Base legal: Art. 15 Decreto 1377 de 2013.

Owl Compliance, NIT [por confirmar], responsable del tratamiento de sus datos personales, le informa:

¿Qué datos recopilamos? Nombre, correo electrónico y contraseña para la creación de su cuenta en la plataforma Owl Compliance.

¿Para qué los usamos? Autenticación y acceso a la plataforma; prestación del servicio de gestión de cumplimiento regulatorio; envío de recordatorios operativos.

¿Con quién los compartimos? Con Turso Inc. (EE.UU.) para almacenamiento en la nube y Resend (EE.UU.) para envío de correos. Ambos países cuentan con nivel adecuado de protección reconocido por la SIC.

Sus derechos: Puede consultar, rectificar, actualizar, suprimir sus datos o revocar su autorización escribiendo a **[COMPLETAR: ej. datos@owlcompliance.co]**. Plazo de respuesta: 10 días hábiles para consultas, 15 días hábiles para reclamos (Art. 14 Ley 1581 de 2012).

Política completa: Disponible en [COMPLETAR: URL, ej. https://owlcompliance.co/privacidad].

Texto para checkbox de autorización (incluir en el formulario)

☐ He leído el Aviso de Privacidad y autorizo el tratamiento de mis datos personales por parte de [COMPLETAR: razón social] para las finalidades descritas, de acuerdo con la Ley 1581 de 2012.

Implementación requerida: Agregar este checkbox con enlace al aviso completo en:

- `app/login/page.tsx` (en el primer login o registro)

- `Formulario de creación de clientes ( app/api/clientes/route.ts )`

- `Conservar timestamp y versión del aviso aceptado en la tabla users``

Mecanismo de Autorización

Mecanismo de Autorización de Tratamiento de Datos — Owl Compliance

Base legal: Arts. 9, 11 Ley 1581 de 2012; Art. 7 Decreto 1377 de 2013.

La autorización debe ser **previa, expresa e informada**. Debe conservarse la prueba.

Estado actual: ✗ NO implementado

La auditoría del código no encontró mecanismo de autorización explícita en ningún flujo de registro o creación de usuarios. Esto es un incumplimiento del Art. 9 Ley 1581.

Cambios de código requeridos

1. Migración de base de datos

Agregar columnas a la tabla `users` para registrar la autorización:

```
`` sql
ALTER TABLE users ADD COLUMN autorizacion_otorgada_at TEXT;
ALTER TABLE users ADD COLUMN autorizacion_texto_version TEXT;
-- Ejemplo: '2026-06-22T22:50:52Z' y 'v1.0'
` `
```

2. Frontend — Formulario de login / registro

En `app/login/page.tsx` (o en el formulario de primer acceso), agregar:

```
` tsx
// Antes del botón de enviar:
<div style={{ marginBottom: '1rem' }}>
<label style={{ display: 'flex', alignItems: 'flex-start', gap: '0.5rem', cursor: 'pointer' }}>
<input
type="checkbox"
required
checked={autorizacion}
onChange={e => setAutorizacion(e.target.checked)}
style={{ marginTop: '2px', flexShrink: 0 }}
/>
<span style={{ fontSize: '0.75rem', color: '#270205', lineHeight: 1.5 }}>
```

```
He leído el{' '}
<a href="/privacidad" target="_blank" style={{ color: '#968622', fontWeight: 700 }}>
Aviso de Privacidad
</a>
{' '}y autorizo el tratamiento de mis datos personales por parte de{' '}
[COMPLETAR: razón social] para las finalidades descritas,
de acuerdo con la Ley 1581 de 2012.
</span>
</label>
</div>
```

3. Backend – Guardar la autorización

```
En lib/clientes.ts , función crearCliente , guardar la autorización al crear el usuario:

`typescript

// Agregar al INSERT de users:

{ sql: INSERT INTO users (id, email, password, nombre, rol, autorizacion_otorgada_at,
autorizacion_texto_version)
VALUES (?, ?, ?, ?, 'cliente', datetime('now'), ?) ,

args: [userId, input.user_email, hashPassword(input.user_password), input.user_nombre, 'v1.0'] }
```

4. Versionar el texto del aviso

Mantener un registro de las versiones del aviso de privacidad:

```
`typescript

// lib/autorizacion-versiones.ts
export const AVISO_VERSION = 'v1.0'

export const AVISO_TEXTO = He leído el Aviso de Privacidad y autorizo el tratamiento...

// Al cambiar el texto, incrementar la versión y notificar a los titulares existentes.
``
```

Excepciones a la autorización previa (Art. 10 Ley 1581)

En los siguientes casos NO se requiere autorización previa del titular:

- Datos de naturaleza pública (información en registros públicos).
- Emergencia médica o sanitaria.
- Tratamiento de datos para fines periodísticos, históricos, estadísticos o científicos.
- Obligación legal o judicial.

Estos casos **no aplican** a los flujos principales de Owl Compliance; se requiere autorización en todos los flujos de registro.

Borrador generado con compliance-co (pack ley-1581). No constituye asesoría legal.

Canal de Habeas Data

Canal de Habeas Data — Owl Compliance

Base legal: Arts. 8, 14-22 Ley 1581 de 2012.

Los titulares tienen derecho a consultar, rectificar, actualizar, suprimir sus datos

y revocar la autorización de tratamiento.

Estado actual: ✗ NO implementado

No existe canal visible para ejercer derechos de Habeas Data. Debe implementarse antes de la siguiente corrida de compliance.

Implementación mínima (sin código adicional)

Mientras se implementa un canal digital, publicar la siguiente información en la política de privacidad y en un pie de página de la app:

Contacto para solicitudes de Habeas Data:

- Email:** [COMPLETAR: ej. datos@owlcompliance.co]
- Asunto del correo:** "Solicitud Habeas Data — [su nombre]"
- Información a incluir:** nombre completo, número de cédula o NIT, descripción de la solicitud, correo de respuesta

Plazos legales de respuesta

Tipo de solicitud	Plazo inicial	Prórroga permitida	Condición de prórroga
(acceso a datos)	5 días hábiles más	Informar al titular antes de que venza el plazo inicial	
(rectificación, actualización, supresión, revocación)	8 días hábiles más	Informar al titular antes de que venza el plazo inicial	

Base legal: Art. 14 Ley 1581 de 2012.

Procedimiento para atender solicitudes

A. Consulta (derecho de acceso)

- Registrar la solicitud: fecha, canal, identidad del titular.
- Verificar identidad del solicitante (cédula o pasaporte).

3. Ubicar todos los datos del titular en la base de datos (tabla `users`, `clientes`, `mensajes`, `audit_log`).
4. Preparar respuesta: qué datos tenemos, para qué finalidad, con quién los compartimos.
5. Enviar en formato legible. **Es gratuita.**
6. Archivar evidencia de la respuesta.

Consulta SQL de apoyo:

```
-- sql

-- Datos del usuario
SELECT id, email, nombre, rol, activo, created_at, autorizacion_otorgada_at
FROM users WHERE email = '[email del titular]';

-- Datos de cliente asociado
SELECT razon_social, nit, contacto, email, telefono
FROM clientes WHERE user_id = '[user_id]';

-- Acciones registradas
SELECT accion, entidad, entidad_id, created_at
FROM audit_log WHERE user_email = '[email]'
ORDER BY created_at DESC;
```

B. Reclamo (rectificación / actualización / supresión / revocación)

1. Registrar el reclamo.
2. Verificar identidad.
3. Marcar el dato como "en revisión" si aplica (para evitar que circule como correcto durante el trámite).
4. Evaluar:

- **Rectificación/actualización:** `UPDATE users SET nombre=? WHERE id=?` (o los campos relevantes).
- **Supresión:** eliminar o anonimizar. Si hay obligación legal de conservar, informar al titular.
- **Revocación:** desactivar cuenta (`activo=0`) y cesar el tratamiento para la finalidad revocada.

5. Responder por escrito con el resultado.
6. Archivar evidencia.

C. Si el titular acude a la SIC

Solo puede hacerlo **después de presentar reclamo ante Owl Compliance** y no obtener respuesta satisfactoria. Si llega un requerimiento de la SIC:

1. Designar un contacto único.
2. Reunir evidencia del trámite previo.
3. Responder en los plazos del requerimiento.

Implementación digital recomendada (Fase 5)

Agregar endpoint en la API:

POST /api/habeas-data

Body: { tipo: 'consulta'|'reclamo', descripcion, nombre, email, cedula }

→ Crea un ticket en la tabla tickets con tipo='habeas_data'

→ Envía confirmación al titular con número de radicado y plazo

→ Notifica al admin responsable

``

Borrador generado con compliance-co (pack ley-1581). No constituye asesoría legal.

Cláusula de Encargados

Cláusula de Encargo de Tratamiento — Owl Compliance

Base legal: Arts. 17, 18 Ley 1581 de 2012; Arts. 25-26 Decreto 1377 de 2013.

Usar con cada proveedor que procese datos personales por cuenta de Owl Compliance.

Proveedores que requieren cláusula de encargo

Proveedor	Datos que procesa	DPA disponible	Estado
	BD completa (usuarios, clientes, mensajes, audit_log)	Verificar en turso.tech/legal	[COMPLETAR: ¿firmado?]
	Email de destinatario + contenido de recordatorios	Verificar en resend.com/legal	[COMPLETAR]
	Tokens OAuth + documentos en Google Drive +	Google Data Processing Amendment (DPA) — aceptar en Google Cloud Console o Google Workspace Admin	[COMPLETAR]
	Tokens OAuth + documentos OneDrive/SharePoint	Microsoft DPA — disponible en microsoft.com/en-us/trust-center	[COMPLETAR]
	Nombre, empresa, cargo, email, teléfono del prospecto (notificación al equipo de ventas)	Verificar en emailjs.com — revisar si ofrecen DPA o si ToS incluye cláusulas de encargo	[COMPLETAR]

Nota: Todos los países son EE.UU., con nivel adecuado reconocido por la SIC. Las relaciones son de transmisión (encargados), no de transferencia a responsables. No se requiere Declaración de Conformidad ni autorización SIC (Circular Única Título V, numerales 3.2 y 3.3).

>

EmailJS — consideración especial: si EmailJS no ofrece DPA, evaluar alternativas como Resend (ya usado) para las notificaciones del autodiagnóstico. El uso de EmailJS sin DPA es un riesgo de cumplimiento bajo para la cantidad de datos transmitidos, pero debe resolverse para cerrar el control data-encargados.

Cláusula tipo para contratos con proveedores

CLÁUSULA [N] — TRATAMIENTO DE DATOS PERSONALES

[N].1 Roles. Para efectos de la Ley 1581 de 2012, **Owl Compliance** actúa como **Responsable del Tratamiento** y **[NOMBRE DEL PROVEEDOR]** actúa como **Encargado del Tratamiento** de los datos personales a los que tenga acceso en virtud del presente contrato.

[N].2 Instrucciones. El Encargado tratará los datos personales **únicamente** siguiendo las instrucciones del Responsable y para las finalidades establecidas en este contrato: [DESCRIBIR, ej. para Turso: "almacenamiento y recuperación de datos en base de datos libSQL"]. Queda prohibido al Encargado: (i) usar los datos para fines propios; (ii) cederlos a terceros sin autorización escrita previa del Responsable; (iii) transferirlos a países sin nivel adecuado de protección.

[N].3 Seguridad. El Encargado adoptará medidas técnicas, administrativas y humanas necesarias para garantizar la seguridad de los datos personales (Art. 17 lit. i Ley 1581; Art. 25 Decreto 1377).

[N].4 Confidencialidad. El Encargado garantiza la confidencialidad, incluso después de terminado el contrato (Art. 18 lit. d Ley 1581).

[N].5 Notificación de incidentes. El Encargado notificará al Responsable **dentro de las 24 horas** siguientes a conocer un incidente de seguridad que afecte los datos personales, con la información necesaria para que el Responsable cumpla su obligación de notificación a la SIC (plazo: 15 días hábiles desde la detección — Circular Única Título V, cap. 2).

[N].6 Sub-encargados. El Encargado no podrá contratar sub-encargados sin autorización previa del Responsable.

[N].7 Devolución y supresión. Al terminar el contrato, el Encargado devolverá o suprimirá todos los datos personales y certificará la supresión por escrito.

[N].8 Auditorías. El Responsable podrá realizar auditorías con preaviso razonable.

Transmisión internacional (EE.UU.)

Los proveedores anteriores se ubican en **Estados Unidos**, país con nivel adecuado de protección de datos reconocido por la SIC (Circular Única — Título V, numeral 3.2, versión 29-09-2022). Por lo tanto:

- **No se requiere Declaración de Conformidad** ante la SIC.
- **No se requiere autorización de la SIC** para estas transmisiones.
- Las garantías se establecen mediante el contrato de encargo descrito arriba.

Si en el futuro se contrata un proveedor en un país **sin** nivel adecuado, se deberá suscribir un contrato con el receptor — lo que hace **presumir la Declaración de Conformidad** (Título V, numeral 3.3, parágrafo), sin necesidad de trámite adicional ante la SIC.

Cómo Owl Compliance actúa como encargado de sus clientes ISP

Cuando los clientes ISP suben documentos de cumplimiento a la plataforma, esos documentos pueden contener datos personales de sus propios empleados o usuarios. En ese caso:

- El **cliente ISP** es el **responsable** del tratamiento de esos datos.
- **Owl Compliance** actúa como **encargado** del ISP.
- El contrato de servicios entre Owl Compliance y el cliente ISP debe incluir la cláusula tipo de encargo (con los roles invertidos).

Acción requerida: Revisar el contrato de servicios con clientes ISP e incluir cláusula de encargo.

Borrador generado con compliance-co (pack ley-1581). No constituye asesoría legal. Revisar con abogado antes de suscribir.

Plan de Respuesta a Brechas

Plan de Respuesta a Brechas de Seguridad — Owl Compliance

Base legal: Art. 17 lit. i Ley 1581 de 2012; Circular Única SIC — Título V, Capítulo Segundo;

Guía de Gestión de Incidentes SIC, dic. 2020.

Plazo para notificar a la SIC: 15 días hábiles desde la detección del incidente.

Estado actual: ✖ NO implementado formalmente

Este documento establece el plan. Debe ser aprobado por [COMPLETAR: representante legal] y comunicado al equipo.

1. Clasificación de incidentes

Nivel	Descripción	Ejemplos	Notificar a SIC
	Acceso no autorizado masivo o exposición de datos de múltiples titulares	Volcado de BD, ransomware, exfiltración	Sí (15 días hábiles)
	Acceso no autorizado a datos de un titular o grupo pequeño	Cuenta de admin comprometida, token OAuth robado	Sí, si hay riesgo real de daño
	Falla de disponibilidad o integridad sin exposición confirmada	Corrupción de datos, error de backup	Evaluar; registrar siempre
	Incidente menor sin impacto en datos personales	Intento fallido de acceso, error de aplicación	No, pero registrar

2. Equipo de respuesta

Rol	Persona	Contacto
Coordinador del incidente	[COMPLETAR: responsable de tratamiento]	[COMPLETAR: teléfono/email]
Técnico	[COMPLETAR: desarrollador principal]	[COMPLETAR]
Comunicaciones (SIC/titulares)	[COMPLETAR: representante legal]	[COMPLETAR]

3. Procedimiento paso a paso

Fase 1: Contención (primeras horas)

1. **Aislar** los sistemas afectados: revocar tokens OAuth comprometidos, reasignar accesos.
2. **Abrir bitácora** del incidente en `registro-incidentes.md`.
3. **Notificar internamente** al coordinador del incidente.
4. Si el incidente involucra un encargado (Turso, Google, Microsoft, Resend): **exigir informe** al proveedor dentro de las 24 horas.
5. Cambiar credenciales: `NEXTAUTH_SECRET`, `TURSO_AUTH_TOKEN`, `GOOGLE_CLIENT_SECRET`, `MICROSOFT_CLIENT_SECRET`, `RESEND_API_KEY`.

Consulta de auditoría para detectar accesos sospechosos:

```
`` sql

-- Acciones recientes en la plataforma
SELECT user_email, accion, entidad, ip, created_at
FROM audit_log
WHERE created_at ≥ datetime('now', '-24 hours')
ORDER BY created_at DESC;

-- Tokens OAuth almacenados (revisar si fueron comprometidos)
SELECT id, storage_type, storage_config FROM clientes WHERE storage_type ≠ 'local';
```

Fase 2: Evaluación (primeras 24-48 horas)

1. Determinar: ¿qué datos fueron expuestos? ¿cuántos titulares? ¿qué riesgo real?
2. Evaluar si la brecha es "significativa" (riesgo real de daño a los titulares).
3. Si hay riesgo real → preparar notificación a la SIC y a los titulares.

Fase 3: Notificación (dentro de 15 días hábiles desde la detección)

A la SIC:

- **Si está inscrito en el RNBD:** reportar a través del portal del RNBD.
- **Si no está inscrito:** reportar por los canales habilitados en sic.gov.co (Delegatura para la Protección de Datos Personales) o correo: [verificar canal vigente en sic.gov.co].
- Incluir: naturaleza del incidente, datos afectados, número de titulares, consecuencias probables, medidas adoptadas.

A los titulares afectados:

- Si hay riesgo real de daño: notificar qué ocurrió, qué riesgo corren, qué medidas tomamos.
- Canal: correo electrónico al email registrado.

Fase 4: Remediación y cierre

1. Identificar causa raíz y corregir la vulnerabilidad.

2. Actualizar el `registro-incidentes.md`.

3. Revisar y actualizar el RAT si cambiaron los datos o los flujos.

4. Re-correr `/compliance-co`` para detectar nuevos huecos.

5. Si aplica: actualizar el RNBD.

4. Vulnerabilidades conocidas que deben remediarse

Las siguientes vulnerabilidades detectadas en la auditoría deben corregirse como medida preventiva:

1. **CRÍTICO — Hashing débil de contraseñas:** SHA-256 con salt fijo es inseguro. Migrar a bcrypt (ya disponible en package.json). Si ocurre una brecha de la BD, todas las contraseñas serían fácilmente recuperables.
2. **ALTO — Tokens OAuth en storage_config:** Los tokens de Google y Microsoft se almacenan en JSON en la BD. Cifrar este campo antes de almacenar.
3. **ALTO — Sin MFA:** Las cuentas de admin no tienen segundo factor. Un credential stuffing compromete el acceso completo.
4. **MEDIO — Sin monitoreo de accesos:** No hay alertas ante patrones sospechosos en el audit_log.

Borrador generado con compliance-co (pack ley-1581). No constituye asesoría legal.

Registro de Incidentes

Registro de Incidentes de Seguridad — Owl Compliance

Base legal: Art. 17 lit. i Ley 1581 de 2012; Guía SIC de Gestión de Incidentes, dic. 2020.

Registrar **todos** los incidentes, aunque no sean notificables a la SIC.

Instrucciones de uso

- 1. Abrir una nueva entrada por cada incidente detectado.
- 2. Completar todos los campos en el momento de la detección.
- 3. Actualizar el estado a medida que avanza la respuesta.
- 4. Archivar como evidencia en caso de inspección SIC.

Registro

#	Fecha detección	Tipo	Descripción	Datos afectados	Titulares afectados	Nivel	Notificado a SIC	Notificado a titulares	Estado	Causa raíz	Acciones correctivas
001	—	—	(sin incidentes registrados)			—	—	—	—	—	—

Próximo número de incidente: 001

Plantilla para nuevo incidente

Incidente #[N]

Fecha y hora de detección: [ISO-8601]

Detectado por: [nombre / sistema]

Tipo de incidente: acceso_no_autorizado | fuga_de_datos | ransomware | error_interno | disponibilidad | otro

Nivel: Crítico | Alto | Medio | Bajo

Descripción

[Qué ocurrió, cómo se detectó]

Datos personales afectados

• Categorías: [usuarios / clientes / mensajes / audit_log / documentos / otros]

- Número estimado de titulares afectados: [N]
- Tipo de datos: [email, nombre, contraseña hash, tokens OAuth, etc.]

Encargados involucrados

[] Turso [] Resend [] Google [] Microsoft [] Otro: _____

Cronología

Fecha/Hora	Acción
[T+0]	Detección
[T+Xh]	Contención
[T+Xh]	Evaluación completada
[T+Xd]	Notificación SIC (si aplica – plazo: 15 días hábiles)
[T+Xd]	Notificación titulares (si aplica)
[T+Xd]	Remediación completada

Notificación a la SIC

- ☐ No aplica (nivel bajo / sin riesgo real)
- ☐ Sí – fecha de envío: [fecha] – canal: [RNBD / sic.gov.co]
- Número de radicado SIC: [si aplica]

Notificación a titulares

- ☐ No aplica
- ☐ Sí – fecha de envío: [fecha] – canal: [email]

Causa raíz

[Descripción técnica de la causa]

Acciones correctivas

1. [Acción 1] – responsable: [nombre] – plazo: [fecha]
2. [Acción 2] – ...

Estado final

- ☐ Abierto
- ☐ Contenido (causa no resuelta)
- ☐ Cerrado – fecha de cierre: [fecha]

``

Procedimiento RNBD

Procedimiento de Inscripción en el RNBD — Owl Compliance

Empresa: Owl Compliance · **NIT:** [NIT por confirmar]
Responsable: Nicolás Almeyda Orozco (Representante Legal)
Fecha: 22 de junio de 2026

¿Quién está obligado a inscribirse? (Circular Única Título V, cap. 2.2)

- Personas jurídicas de derecho privado con **activos totales superiores a 100.000 UVT** al 31 de diciembre del año anterior.
- Personas jurídicas de **naturaleza pública**.
- Las personas naturales y las empresas con activos ≤ 100.000 UVT **no están obligadas** (pueden inscribirse voluntariamente).

>

Base legal: Arts. 25-26 Ley 1581; Decreto 90 de 2018; Circular Única Título V.

*Plataforma: **rnbd.sic.gov.co***

Determinación de la obligación

Tamaño de la empresa: Microempresa
Activos totales al 31 dic del año anterior: ≤ 100.000 UVT (confirmado por el responsable)
Naturaleza: Persona jurídica privada
Conclusión:

- ✔ **No obligada** — microempresa con activos ≤ 100.000 UVT, de naturaleza privada. La inscripción en el RNBD no es exigible (Circular Única Título V, cap. 2.2). Sin riesgo de sanción por no inscribirse. Inscripción voluntaria no requerida por ahora.

Verificar anualmente: si los activos superan el umbral de 100.000 UVT en algún ejercicio, la obligación de inscripción surgirá en el período siguiente.

Estado actual

- ✔ **No inscrita — no obligada.** No se requiere acción. Revisar umbral anualmente.

Bases de datos a inscribir (si aplica la obligación)

#	Nombre de la base	Categorías de datos	Finalidad	Titulares	¿Datos sensibles?	Países de transmisión
1	Usuarios del sistema	Nombre, email, password (hash), rol	Autenticación y acceso	Admins y representantes de clientes	No	EE.UU. (Turso)
2	Clientes (empresas ISP)	Razón social, NIT, contacto, email, teléfono	Prestación del servicio	Representantes de empresas ISP	No	EE.UU. (Turso, Resend)
3	Mensajes y conversaciones	Contenido de mensajes, user_id	Soporte y comunicación	Usuarios de la plataforma	No	EE.UU. (Turso)
4	Documentos de cumplimiento	Nombre de archivo, metadatos	Acreditación de cumplimiento	Admins y representantes	No	EE.UU. (Turso, Google, Microsoft)
5	Bitácora de auditoría	user_email, acciones, IP	Seguridad y trazabilidad	Usuarios de la plataforma	No	EE.UU. (Turso)

Plazos (si está inscrita o se inscribe)

- **Cambios materiales:** dentro de los primeros 10 días hábiles del mes siguiente al cambio.
- **Actualización anual:** entre el **2 de enero y el 31 de marzo** de cada año.
- **Reporte de reclamos:** primeros **15 días hábiles** de febrero y agosto.

Consecuencias de no inscribirse (solo si es obligada)

La no inscripción puede ser sancionada por la SIC (multas hasta 2.000 SMMLV). Si la empresa no está obligada (activos ≤ 100.000 UVT), este riesgo no aplica directamente. Verificar el umbral anualmente.

Borrador generado con compliance-co (pack ley-1581). No constituye asesoría legal.

Evaluación de Impacto (EIPD)

Evaluación de Impacto en Protección de Datos (EIPD) — Owl Compliance

La Ley 1581 de 2012 no exige formalmente la EIPD. Es una **buena práctica** recomendada por la SIC y el estándar internacional (equivalente al DPIA del GDPR). Se recomienda hacerla cuando:

(a) el tratamiento involucra datos sensibles, (b) hay menores de edad, (c) hay perfilado sistemático, o (d) el tratamiento puede generar riesgo significativo para los titulares.

Empresa: Owl Compliance · **NIT:** [por confirmar]

Fecha: 22 de junio de 2026

Versión: 1.0

¿Por qué se recomienda esta EIPD?

Aunque Owl Compliance no trata datos sensibles ni de menores, la EIPD se recomienda porque:

1. La plataforma gestiona documentos de cumplimiento de empresas ISP que pueden contener datos personales de terceros.
2. Un incidente de seguridad en la plataforma podría afectar a múltiples empresas cliente simultáneamente (efecto multiplicador).
3. Turso (BD en la nube, EE.UU.) concentra todos los datos de la plataforma.
4. Los tokens OAuth de Google/Microsoft almacenados en BD representan un riesgo alto si son comprometidos.

1. Descripción del tratamiento

Responsable: Owl Compliance — Nicolás Almeyda Orozco (Representante Legal)

Naturaleza del tratamiento: Plataforma SaaS B2B de gestión de cumplimiento regulatorio para ISPs colombianos. Procesa datos de identificación y contacto de representantes de empresas, documentos de cumplimiento, mensajes de chat y registros de auditoría.

Alcance: [COMPLETAR: número estimado de clientes ISP] empresas cliente, [COMPLETAR: número estimado de usuarios] usuarios de la plataforma.

Contexto: Cloud-based (Turso + Fly.io), Next.js, multi-tenant.

2. Evaluación de necesidad y proporcionalidad

Dato recopilado	¿Necesario?	¿Proporcional?	¿Alternativa menos intrusiva?
-----------------	-------------	----------------	-------------------------------

Email del usuario	Sí — identificación y comunicación		Sí	No aplica
Contraseña (hash)	Sí — autenticación	Sí	Considerar magic link o SSO	
Nombre	Sí — identificación en la plataforma		Sí	No aplica
Teléfono del cliente ISP	Opcional — comunicación		Aceptable	Podría ser voluntario
Tokens OAuth (Google/Microsoft)	Sí — integración con almacenamiento		Sí, pero riesgo alto	Cifrar en BD antes de guardar
IP en audit_log	Sí — seguridad	Sí	Considerar seudonimización (hash de IP)	

3. Evaluación de riesgos

Riesgo	Probabilidad	Impacto	Nivel	Control existente	Control propuesto
Compromiso de contraseñas por hashing débil (SHA-256)	Alta	Alto		Ninguno (SHA-256 es débil para passwords)	Migrar a bcrypt (urgente)
Robo de tokens OAuth almacenados en BD	Media	Alto		Control de acceso por rol	Cifrar storage_config en BD
Acceso no autorizado a cuentas de admin	Media	Crítico		Autenticación con email+password	Implementar MFA
Fuga de datos en Turso (BD en la nube)	Baja	Alto	Medio	TLS, autenticación con token	Revisar políticas de Turso; DPA
Acceso indebido entre clientes ISP (fuga de segregación)	Baja	Alto	Medio	Segregación por cliente_id en todas las queries	Audit periódico de queries; tests de segregación
Pérdida de datos por fallo de BD	Baja	Alto	Medio	Turso gestiona backups	Documentar RTO/RPO; probar restauración

4. Medidas para mitigar los riesgos

Prioritarias (implementar antes de procesar más datos):

- ⚠️ **Migrar hashing de contraseñas a bcrypt** — `lib/auth.ts` y `lib/clientes.ts`. Ya disponible: `bcryptjs@3.0.3`.
- ⚠️ **Cifrar tokens OAuth** en la columna `storage_config` antes de guardar en BD.
- ⚠️ **Implementar MFA** para cuentas de admin.

A mediano plazo:

- Publicar aviso de privacidad y mecanismo de autorización.
- Habilitar canal de Habeas Data.
- Firmar DPA con Turso, Resend, Google, Microsoft.
- Seudonimizar IPs en audit_log (reemplazar por hash).
- Implementar alertas sobre audit_log.

5. Conclusión

Aspecto	Estado
¿Tratamiento necesario y proporcional?	Sí, con ajustes menores
¿Riesgos residuales aceptables?	No — hay 3 riesgos altos/críticos pendientes de remediación
¿Requiere notificación a SIC?	No (EIPD no es obligatoria en Colombia)
¿Requiere aprobación del DPO?	Recomendable — designar responsable de tratamiento formalmente

Próxima revisión: [COMPLETAR: ej. junio 2027] o ante cambios materiales en el tratamiento.

Borrador generado con compliance-co (pack ley-1581). No constituye asesoría legal.

Instructivo Operativo

Instructivo operativo — Owl Compliance (Ley 1581 de 2012)

Qué hacer ante cada situación. Consultar este archivo cuando pase algo.

El responsable ejecuta esto solo; el abogado solo entra en representación formal ante la SIC.

A. Llega una solicitud de Habeas Data

A.1 Consulta (derecho de acceso)

Plazo: 10 días hábiles (prorrogable 5 días hábiles más, **avisando al titular antes de vencer**).

- 1. Registrar la solicitud (fecha, canal, identidad).
- 2. Verificar identidad del titular (cédula o pasaporte).
- 3. Ejecutar consulta en la BD:

```
`` sql

SELECT id, email, nombre, rol, created_at FROM users WHERE email = '[email]';
SELECT razon_social, nit, contacto FROM clientes WHERE user_id = '[user_id]';
SELECT accion, entidad, created_at FROM audit_log WHERE user_email = '[email]' ORDER BY created_at DESC;
```

- 4. Preparar respuesta: qué datos tenemos, para qué, con quién los compartimos.
- 5. Enviar en formato legible. **Es gratuita.**
- 6. Archivar evidencia.

A.2 Reclamo (rectificación / supresión / revocación)

Plazo: 15 días hábiles (prorrogable 8 días hábiles más, **avisando antes de vencer**).

- 1. Registrar el reclamo.
- 2. Verificar identidad.
- 3. Evaluar:

- **Rectificación:** UPDATE users SET nombre=? WHERE id=? (o campo correspondiente).
- **Supresión:** desactivar cuenta (UPDATE users SET activo=0). Si hay obligación legal de conservar, informar al titular.
- **Revocación:** desactivar cuenta y cesar el tratamiento para esa finalidad.

4. Responder por escrito.

5. Archivar evidencia.

A.3 El titular acude a la SIC

Solo puede hacerlo después de presentar reclamo ante Owl Compliance. Si llega requerimiento SIC:

1. Designar un contacto único.
2. Reunir evidencia: reclamo original, respuesta dada, fechas.
3. Responder en los plazos del requerimiento.

Canal para solicitudes: [COMPLETAR: ej. datos@owlcompliance.co]

B. Brecha de seguridad

Plazo para notificar a la SIC: 15 días hábiles desde la detección (Circular Única Título V versión 29-09-2022, cap. 2; Guía SIC de Gestión de Incidentes, dic. 2020).

1. **Contén:** rota credenciales inmediatamente:

- TURSO_AUTH_TOKEN → regenerar en console.turso.tech
- GOOGLE_CLIENT_SECRET / MICROSOFT_CLIENT_SECRET → regenerar en Google Cloud / Azure Portal
- NEXTAUTH_SECRET → cambiar en Fly.io secrets
- RESEND_API_KEY → regenerar en resend.com

2. **Evalúa:** qué datos, cuántos titulares, nivel de riesgo.

3. **Notifica a la SIC** (si brecha significativa):

- Si inscrito en RNBD: reportar por el portal del RNBD.
- Si no inscrito: canal en sic.gov.co (Delegatura Protección Datos).
- Incluir: naturaleza, datos afectados, número de titulares, medidas adoptadas.

4. **Notifica a los titulares** si hay riesgo real de daño.

5. **Registra** el incidente en docs/1581-registro-incidentes.md .

6. **Cierra:** causa raíz + fix técnico + actualiza EIPD y RAT.

Ver plan completo: docs/1581-plan-respuesta-brechas.md .

C. Inspección SIC

1. Designar contacto único. Todo por escrito.
2. Identificar si es solicitud de información (preliminar) o investigación formal.

3. Reunir antecedentes:este directorio .compliance/ – RAT, autorizaciones, políticas, canal Habeas Data, cláusulas de encargo, registro de incidentes, EIPD.

- 4. Responder en plazo, cargo por cargo. Mostrar diligencia y remediación.
- 5. Atenuantes: tamaño de empresa, corrección rápida, colaboración con la SIC.
- 6. Si escala a pliego de cargos formal: considerar asesoría legal especializada.

D. Calendario de cumplimiento

Cuándo	Qué	Quién
	Agregar aviso de privacidad y checkbox de autorización al login	Dev
	Migrar contraseñas de SHA-256 a bcrypt	Dev
	Cifrar tokens OAuth en storage_config	Dev
	Habilitar canal de Habeas Data (email mínimo, luego endpoint)	Responsable de tratamiento + Dev
	Firmar DPA con Turso, Resend, Google, Microsoft	Responsable de tratamiento
	Implementar MFA para cuentas de admin	Dev
	Actualización anual RNBD (si obligada: activos > 100.000 UVT)	Responsable
	Reportar reclamos en el RNBD (si inscrita)	Responsable
	Reportar cambios materiales en el RNBD (si inscrita)	Responsable
	Revisar y actualizar el RAT	Responsable
	Capacitación del equipo sobre protección de datos	Responsable
	Cláusula de encargo + verificar transmisión internacional	Responsable
	Re-correr /compliance-co (detectar drift)	Dev
	Actualizar sources/ y re-correr	Responsable + Dev

E. Ante cambios de ley o nuevas circulares SIC

- 1. Descargar texto actualizado de sic.gov.co o secretariasenado.gov.co.

- 2. Guardar en D:\OWL\Administrativo\Datos Personales\skills\compliance-co\sources\ .

- 3. Ajustar el pack y los controles afectados.

4. Re-correr `/compliance-co` → el `state.json`` muestra qué cambió.

Instructivo operativo generado con compliance-co (pack ley-1581). No constituye asesoría legal.